

Enterprise Network Hardening & Risk Mitigation Using CIS Controls

Ethan Messer

MGS 427

12/14/2025

Table of Contents

Executive Summary.....	3
Technical Findings.....	4
CIS Control – Secure Configuration of Enterprise Assets and Software.....	4
CIS Control – Access Control Management.....	6
CIS Control – Audit Log Management	8
Hardening Task:	10
OPT1	10
LAN	10
WAN	11
FLOATING	11
Topology.....	12
Work Cited	13
Appendix.....	14

Executive Summary

This project documents the deployment, design, and security hardening of the Catflix infrastructure. A v multi-virtual environment developed to support the administrative documentation of internal training operations. The network was built using different segmented architecture to separate administrative and server resources, with security controls that when applied preserve confidentiality, integrity, and availability across all systems.

To reduce the organizational risk, three CIS Critical Security Controls were implemented in addition to the baseline security firewall hardening: Secure Configuration of Enterprise Assets and Software, Access Control Management, and Audit Log Management. The systems were hardened through secure configurations, limiting administrative access based on least privilege principles, and centralized logging to help improve visibility into security-relevant events. When doing these this mitigated common threats such as unauthorized access, misconfiguration-based exploitation, and undetected malicious activity.

Following implementation, the Catflix Wiki remained fully operational and accessible to authorized users, confirming that applied security controls did not negatively impact system availability. Resulting in the infrastructure that balanced the approach to risk management, providing Catflix with a secure, maintainable, and resilient platform capable of supporting ongoing business operations while reducing exposure to cyber threats.

Technical Findings

CIS Control – Secure Configuration of Enterprise Assets and Software

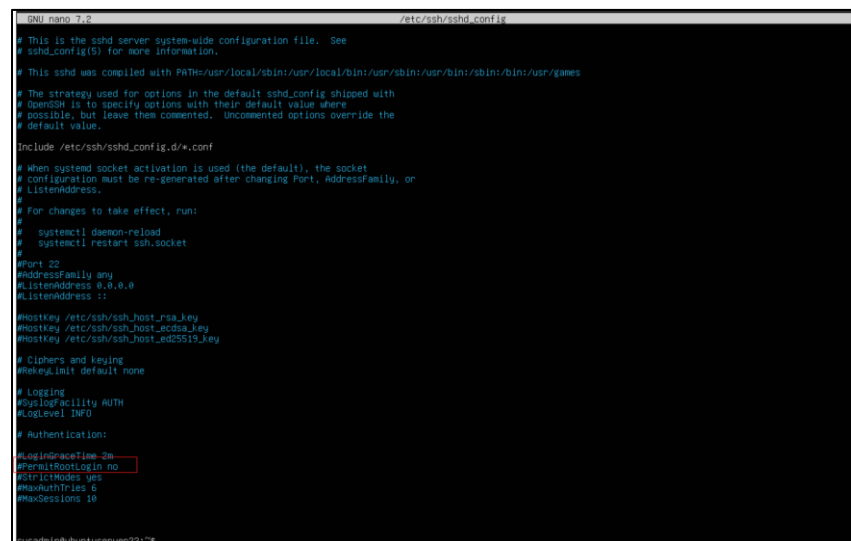
CIS Control Secure Configuration of Enterprise Assets and Software recommends establishing and maintaining secure configurations for enterprise assets and software to reduce exposure created by insecure default settings and misconfigurations (Center for Internet Security).

Control Category: Secure Configuration of Enterprise Assets and Software

Measure Applied: System hardening through secure default configurations on Catflix server assets

UBNetDef implemented secure configuration controls across the Catflix server infrastructure to reduce exposure to misconfiguration-based threats. On Linux servers supporting the Catflix Wiki environment, insecure default settings were modified to align with industry best practices.

Administrative remote access was hardened by disabling direct root authentication over SSH, reducing the risk of credential brute-force attacks. Automated security updates were enabled to ensure timely application of critical patches without requiring manual intervention. On the database server, the MariaDB secure installation process was completed to remove unnecessary default accounts, restrict remote administrative access, and enforce strong authentication practices.



```
GNU nano 2.9.2 /etc/ssh/sshd_config
# This is the sshd server system-wide configuration file. See
# sshd_config(5) for more information.
# This sshd was compiled with PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games
# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented. Uncommented options override the
# default value.
# Include /etc/ssh/sshd_config.d/*.conf
# When systemd socket activation is used (the default), the socket
# configuration must be re-generated after changing Port, AddressFamily, or
# ListenAddress.
# For changes to take effect, run:
#
# systemctl daemon-reload
# systemctl restart ssh.socket
#
#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::
#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key
#
# Ciphers and keying
#Ciphers none
#KeyExchange default none
#
# Logging
#SyslogFacility AUTH
#LogLevel INFO
#
# Authentication:
#
#LoginGraceTime 2m
#PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

Figure 1 UbuntuWebServer SSH Configuration - Root Login Disabled.

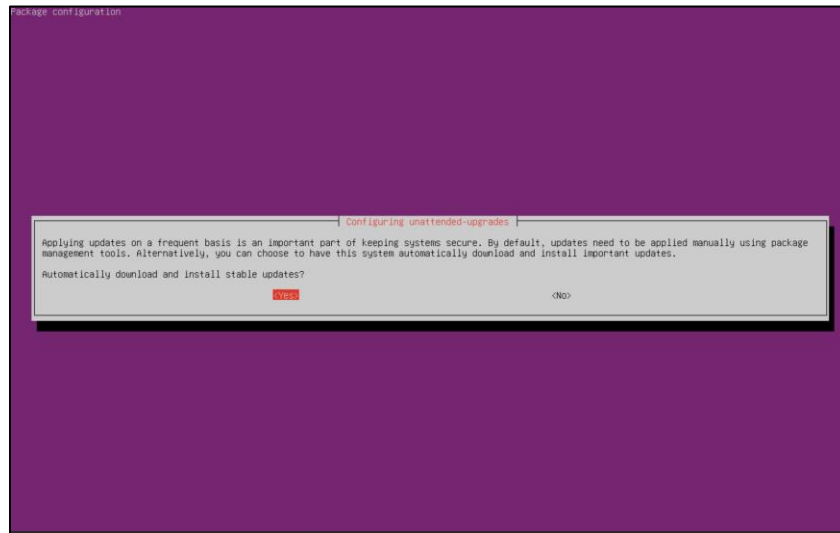


Figure 2 UbuntuWebServer Automatic Security Updates Enabled.

```
[sysadmin@localhost ~]$ sudo mysql -e "SELECT user,host FROM mysql.user;"
ERROR 1045 (28000): Access denied for user 'root'@'localhost' (using password: NO)
[sysadmin@localhost ~]$ _
```

Figure 3 MySQL Service on RockyDBServer is securely configured to deny unauthenticated root access, preventing unauthorized administrative controls of the database. This will reduce the risk of credential abuse, privilege escalation, and data compromises.

These measures will mitigate risks associated with the default credentials, unpatched vulnerabilities, and excessive administrative exposure. Then reducing the attack surface created by insecure configurations, Catflix limits the likelihood of unauthorized access, service compromise, and data integrity violations.

From a business perspective, the secure configuration reduces operational risk by lowering the probability rate of outages or breaches caused by preventable configuration errors. Automated patching and hardened access controls also reduce administrative overhead while improving long-term system reliability, which will allow Catflix to scale services without proportionally increasing security management costs.

CIS Control – Access Control Management

CIS Control Access Control Management emphasizes managing access rights and privileges to enforce least privilege and reduce the risk of unauthorized administrative actions across enterprise systems (Center for Internet Security).

Access control management was implemented to ensure that administrative privileges within the Catflix Wiki interface environment were restricted to the authorized users only. Administrative access to network infrastructure devices was limited through the controlled user accounts, and default credentials, which were removed or replaced. Within the Windows domain environment, administrative roles were assigned through designated security groups rather than individual accounts groups, providing centralized control and accountability. On Linux systems, the sudo and wheel group membership was limited to required administrative users. Within the MediaWiki application, only a single authorized administrative account was granted the elevated privileges.

The screenshot displays the 'User Properties' form in the User Manager interface. The breadcrumb trail at the top reads 'System / User Manager / Users / Edit'. Below this, there are tabs for 'Users', 'Groups', 'Settings', and 'Authentication Servers'. The 'Users' tab is selected. The form contains the following fields and options:

- Defined by:** SYSTEM
- Disabled:** ☐ This user cannot login
- Username:** admin
- Password:** Two input fields, both containing masked characters (*****). The first field is highlighted with a red border.
- Full name:** System Administrator (with a subtext: 'User's full name, for administrative information only')
- Expiration date:** (empty field, with a subtext: 'Leave blank if the account shouldn't expire, otherwise enter the expiration date as MM/DD/YYYY')
- Custom Settings:** ☐ Use individual customized GUI options and dashboard layout for this user.
- Group membership:** A dropdown menu showing 'admins' as the selected group. Below the dropdown are labels 'Not member of' and 'Member of'.

An 'Activate Windows' watermark is visible in the bottom right corner of the form area.

Figure 4 Administrative User Access Control, Adding a password.

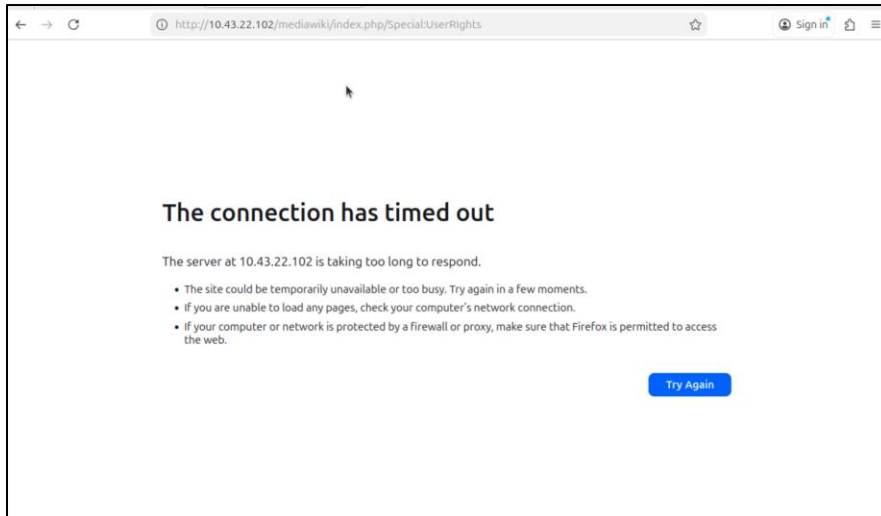


Figure 5 Enforced Access Control Blocking unauthorized Administrative Access to MediaWiki.

```
sysadmin@ubuntuserver22:~$ getent group sudo
sudo:x:27:sysadmin
sysadmin@ubuntuserver22:~$
```

Figure 6 Getent group sudo

```
[sysadmin@localhost ~]$ getent group wheel
wheel:x:10:sysadmin
[sysadmin@localhost ~]$
```

Figure 7 RockyDBServer Wheel Group Membership

These controls will mitigate the risk of privilege abuse, which will cause lateral movement, and unauthorized configuration changes. Restricting administrative access reduces the impact of compromised credentials and then limits the potential blast radius of insider threats or misconfigured accounts.

CIS Control – Audit Log Management

Audit logging controls were implemented to provide visibility into security-relevant activity across the Catflix Wiki infrastructure. The system authentication logs, web server access and error logs, and service logs were enabled then verified on server hosts. This persistent logging was configured to ensure that the logs remain available across reboots, supporting both real-time monitoring and post-incident investigation. Database and operating system logs were reviewed to confirm proper recording of access attempts and system events.

[illegible]

```
sysadmin@ubuntuserver22:~$ sudo tail -n 50 /var/log/apache2/access.log
```

8


```

sysadmin@ubuntu22:~$ ls -ld /var/log/journal
drwxr-sr-x+ 3 root systemd-journal 4096 Dec 13 02:52 /var/log/journal
sysadmin@ubuntu22:~$

```

Figure 10 UbuntuWebServer Persistent System Logging Enabled

```

sysadmin@localhost ~1$ sudo journalctl _COMM=sshd --no-pager | tail -n 30
-- Logs begin at Fri 2025-12-12 22:25:04 EST, end at Sun 2025-12-14 20:26:33 EST. --
Dec 12 22:25:09 localhost.localdomain sshd[7951]: Server listening on 0.0.0.0 port 22.
Dec 12 22:25:09 localhost.localdomain sshd[7951]: Server listening on :: port 22.
Dec 13 13:57:35 localhost.localdomain sshd[7951]: Received signal 15; terminating.
Dec 13 13:57:36 localhost.localdomain sshd[389491]: Server listening on 0.0.0.0 port 22.
Dec 13 13:57:36 localhost.localdomain sshd[389491]: Server listening on :: port 22.
sysadmin@localhost ~1$

```

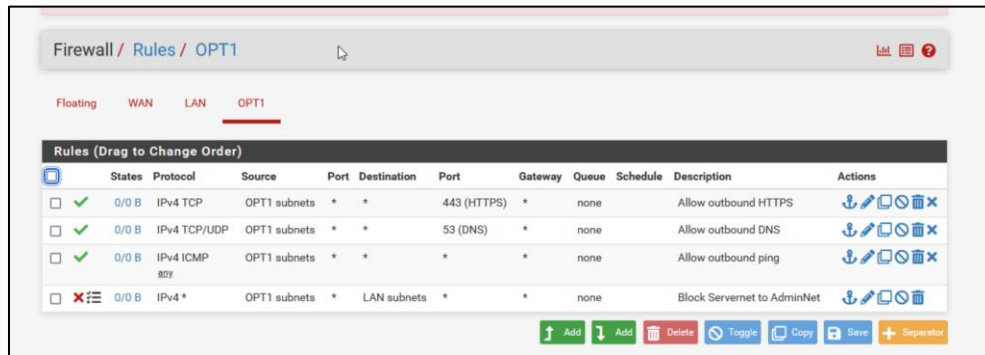
Figure 11 SSH Authentication Event Logged via sytem journalctl on RockyDBServer

These measures will mitigate the risk of undetected malicious activity by enabling timely identification of suspicious behavior such as the unauthorized login attempts or abnormal service usage. Effective log management, which supports incident response by preserving forensic evidence needed to analyze security events.

From a business standpoint, the audit log management enhances Catflix’s ability to respond to incidents efficiently, reducing downtime and potential data loss. Improved visibility into system activity also supports operational troubleshooting and strengthens trust in the reliability and transparency of the Catflix Wiki platform.

Hardening Task:

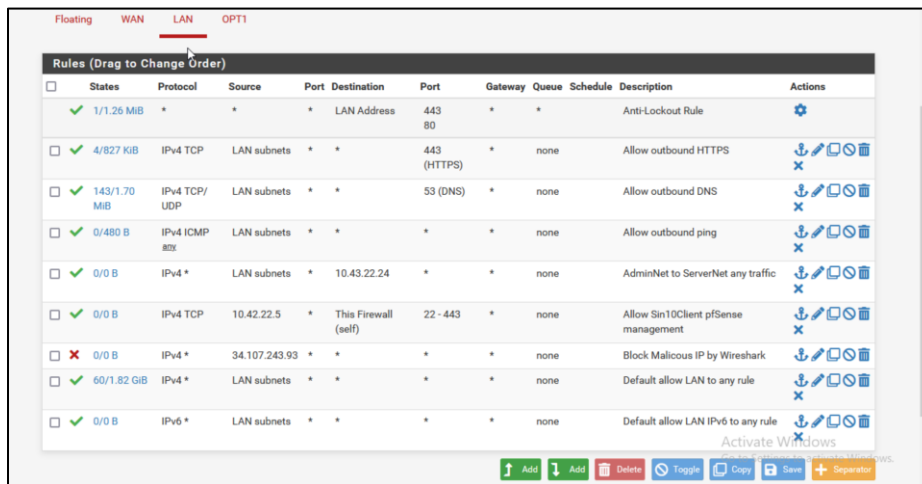
OPT1



	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 TCP	OPT1 subnets	*	*	443 (HTTPS)	*	none	Allow outbound HTTPS	
☐	✓	0/0 B	IPv4 TCP/UDP	OPT1 subnets	*	*	53 (DNS)	*	none	Allow outbound DNS	
☐	✓	0/0 B	IPv4 ICMP	OPT1 subnets	*	*	*	*	none	Allow outbound ping	
☒	✗	0/0 B	IPv4 *	OPT1 subnets	*	LAN subnets	*	*	none	Block ServerNet to AdminNet	

Figure 12 The OPT1 firewall rules will limit the ServerNet outbound traffic to be essential for services and block all traffic destined for AdminNet. This rule blocks all lateral movement from server systems into administrative networks.

LAN



	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	1/1.26 MB	*	*	*	LAN Address	443 80	*	*	Anti-Lockout Rule	
☐	✓	4/827 KIB	IPv4 TCP	LAN subnets	*	*	443 (HTTPS)	*	none	Allow outbound HTTPS	
☐	✓	143/1.70 MIB	IPv4 TCP/UDP	LAN subnets	*	*	53 (DNS)	*	none	Allow outbound DNS	
☐	✓	0/480 B	IPv4 ICMP	LAN subnets	*	*	*	*	none	Allow outbound ping	
☐	✓	0/0 B	IPv4 *	LAN subnets	*	10.43.22.24	*	*	none	AdminNet to ServerNet any traffic	
☐	✓	0/0 B	IPv4 TCP	10.42.22.5	*	This Firewall (self)	22 - 443	*	none	Allow Sin10Client pfSense management	
☒	✗	0/0 B	IPv4 *	34.107.243.93	*	*	*	*	none	Block Malicious IP by Wireshark	
☐	✓	60/1.82 GIB	IPv4 *	LAN subnets	*	*	*	*	none	Default allow LAN to any rule	
☐	✓	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none	Default allow LAN IPv6 to any rule	

Figure 13 The LAN firewall rules will restrict administrative access to pfSense management interfaces by single authorizing an endpoint and limiting the outbound traffic to essential protocols. This will cause full access from AdminNet to ServerNet and will support system administration task.

WAN

Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0/175 KB	*	RFC 1918 networks	*	*	*	*	*		Block private networks	
☒	0/3.19 MB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	
☐	0/0 B	IPv4 TCP	10.43.22.102	*	*	80 (HTTP)	*	none		Allow HTTP to Catflix Wiki	
☐	0/0 B	IPv4 TCP	*	*	10.43.22.102	443 (HTTPS)	*	none		Allow HTTPS to Catflix Wiki	

Figure 14 This WAN firewall rule will enforce a default-deny posture for external traffic, which will be allowing only HTTP and HTTPS access the Catflix Admin Wiki while blocking all the other inbound connections. This will limit the internet exposure to the minimum services required for Catflix operations.

FLOATING

Floating

WAN

LAN

OPT1

Rules (Drag to Change Order)

	States	Interfaces	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
--	--------	------------	----------	--------	------	-------------	------	---------	-------	----------	-------------	---------

No floating rules are currently defined. Click the button to add a new rule.

↑

Add

↓

Add

🗑

Delete

🔄

Toggle

💾

Save

+

Separator

i

Figure 15 No floating firewall rules were configured, ensuring that all the traffic being filtered out is handled by the interface level. This will improve the rule clarity and reduce the risk of unintended policy interactions

Topology

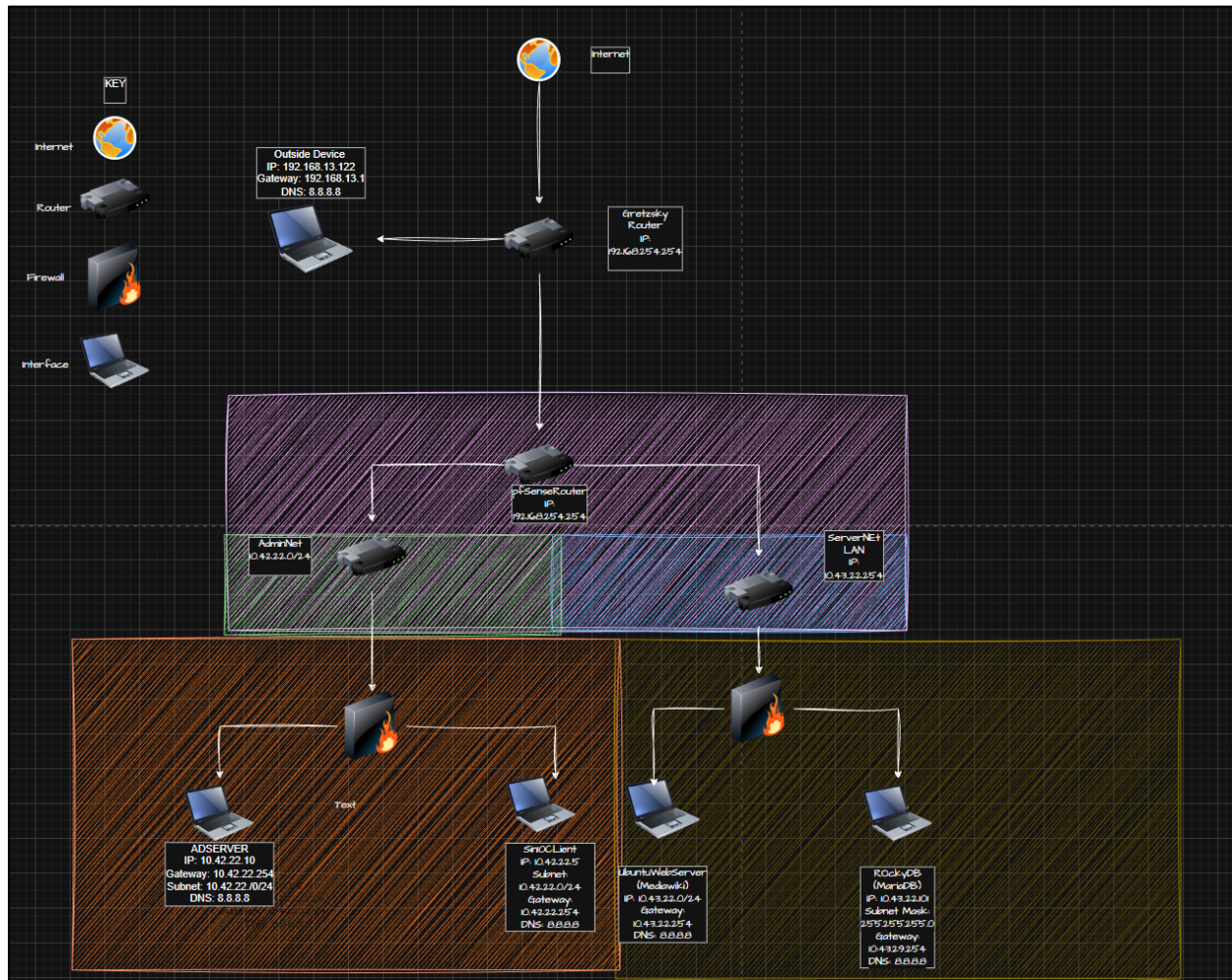


Figure 16 The Catflix Wiki network is a segmented architecture secured by a pfSense firewall that separates external traffic, administrative systems, and server resources. AdminNet contains authorized administrative workstations with controlled access to ServerNet, while ServerNet hosts production services and is prevented from initiating traffic back into AdminNet to limit lateral movement. External access is restricted at the WAN interface to only HTTP and HTTPS traffic to the Catflix Wiki, enforcing a default-deny security posture while maintaining system availability.

Work Cited

Center for Internet Security. CIS Critical Security Controls Version 8. Center for Internet Security, <https://www.cisecurity.org/controls/cis-controls-list>.

Center for Internet Security. CIS Control 4: Secure Configuration of Enterprise Assets and Software. Center for Internet Security, <https://www.cisecurity.org/controls/cis-control-4-secure-configuration-of-enterprise-assets-and-software>.

Center for Internet Security. CIS Control 6: Access Control Management. Center for Internet Security, <https://www.cisecurity.org/controls/cis-control-6-access-control-management>.

Center for Internet Security. CIS Control 8: Audit Log Management. Center for Internet Security, <https://www.cisecurity.org/controls/cis-control-8-audit-log-management>.

Appendix

Hardening Task:	10
OPT1	10
LAN	10
WAN	11
FLOATING	11
Topology.....	12